

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-05 07:00 WIB

Top 5 Highlights

- CVE-2026-12746 | Dancer2::Plugin::Auth::OAuth::Provider up to 0.22 OAuth 2.0 Flow authentication_url/callback state cross-site request forgery
- CVE-2026-12740 | Plack::Middleware::OAuth up to 0.10 OAuth 2.0 State RequestTokenV2/AccessTokenV2 state cross-site request forgery
- CVE-2026-14764 | code-projects Hotel and Tourism Reservation 1.0 Event Management Page /admin/add_event.php fdetails sql injection
- CVE-2026-14763 | code-projects Hotel and Tourism Reservation 1.0 Tour Reservations Page /admin/tour_reserves.php tour sql injection
- CVE-2026-14762 | code-projects Hotel and Tourism Reservation 1.0 Room Management Page /admin/rooms.php delete sql injection

Threat Intelligence (10)

01. North Korean Hackers Publish 108 Malicious Packages and Extensions in PolinRider Campaign

The North Korean threat actors linked to the Contagious Interview campaign have been observed publishing 108 unique packages and web browser extensions spanning npm, Packagist, Go, and Google Chrome as part of an ongoing activity referred to as PolinRider. "The campaign remains active, and new malicious packages are likely to continue appearing as threat ac...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/north-korean-hackers-publish-108.html>

02. [+24h Old] New Avalon Malware Framework Packs CrownX Ransomware Capabilities

Cybersecurity researchers have discovered a previously undocumented modular malware framework codenamed Avalon that's distributed by means of a multi-stage phishing chain capable of bypassing traditional security controls. Avalon combines credential collection, lateral movement, remote access, recovery disruption, and ransomware execution, bringing together...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/new-avalon-malware-framework-packs.html>

03. [+24h Old] AdaptHealth says attackers sweet-talked their way into cloud systems and stole patient data

Third-party contractor compromise exposed health information and insurance billing passwords

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/07/03/adapthealth-crooks-stole-our-passwords-patient-health-data/5266512>

04. [+24h Old] ARToken PhaaS exposes EvilTokens' Microsoft 365 phishing toolkit

A new phishing-as-a-service (PhaaS) platform dubbed "ARToken" appears to operate as an affiliate of the EvilTokens phishing platform, giving researchers a glimpse into an extensive toolkit designed to compromise Microsoft 365. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/artoken-phaas-exposes-eviltokens-microsoft-365-phishing-toolkit/>

05. [+24h Old] Armored Likho Targets Government Agencies, Power Sector with BusySnake Stealer

A previously undocumented threat actor known as Armored Likho has been attributed to cyber attacks targeting government agencies and the electric power sector across Russia, Brazil, and Kazakhstan. "Armored Likho blends financially motivated campaigns targeting private individuals with targeted cyber espionage aimed at organizations," Kaspersky said in a te...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/armored-likho-targets-government.html>

06. [+24h Old] Verified X ad spreads Mac malware, while ConsentFix steals Microsoft accounts

Two new campaigns show how cybercriminals are increasingly relying on social engineering instead of software exploits to compromise devices and accounts.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/07/verified-x-ad-spreads-mac-malware-while-consentfix-steals-microsoft-accounts>

07. [+24h Old] NetNut cracked as Google and FBI target 2 million-device botnet

Other residential proxy brands may rely on the same network

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/07/03/netnut-cracked-as-google-and-fbi-target-2-million-device-botnet/5266414>

08. [+24h Old] Armored Likho digging a snake pit: inside the covert BusySnake Stealer campaign

An inside look at the active Armored Likho APT campaign. The attackers are using spear-phishing, AI-generated loaders, and a new Python-based tool, BusySnake Stealer, to target organizations in Russia, Kazakhstan, and Brazil.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://securelist.com/tr/armored-likho-apt-with-busysnake-stealer/120292/>

09. [+24h Old] FBI, Google Take Down NetNut Proxy Network Used by Cyber Threat Actors

The NetNut proxy network and the 'Popa' botnet are known to have infected devices with variants of Mirai DDoS botnets

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/fbi-google-take-down-netnut-proxy/>

10. [+48h Old] FBI Seizes NetNut Proxy Platform, Popa Botnet

The Federal Bureau of Investigation (FBI) said today it worked with industry partners to seize hundreds of domains associated with NetNut, a sprawling residential proxy service operated by the publicly-traded Israeli company Alarum Technologies [NASDAQ: ALAR]. The action comes roughly two weeks after KrebsOnSecurity published findings from multiple security...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://krebsonsecurity.com/2026/07/fbi-seizes-netnut-proxy-platform-popa-botnet/>

Latest Vulnerabilities (10)

01. CVE-2026-12746 | Dancer2::Plugin::Auth::OAuth::Provider up to 0.22 OAuth 2.0 Flow authentication_url/callback state cross-site request forgery

A vulnerability was found in Dancer2::Plugin::Auth::OAuth::Provider up to 0.22 . It has been declared as problematic . Affected by this vulnerability is the function authentication_url/callback of the component OAuth 2.0 Flow Handler...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuln.db.com/vuln/376355>

02. CVE-2026-12740 | Plack::Middleware::OAuth up to 0.10 OAuth 2.0 State RequestTokenV2/AccessTokenV2 state cross-site request forgery

A vulnerability was found in Plack::Middleware::OAuth up to 0.10 . It has been classified as problematic . Affected is the function RequestTokenV2/AccessTokenV2 of the component OAuth 2.0 State Handler . Performing a manipulation of the argument state results in cross-site request forgery. This vulnerability was named CVE-2026-12740...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376354>

03. CVE-2026-14764 | code-projects Hotel and Tourism Reservation 1.0 Event Management Page /admin/add_event.php fdetails sql injection

A vulnerability was found in code-projects Hotel and Tourism Reservation 1.0 and classified as critical . This impacts an unknown function of the file /admin/add_event.php of the component Event Management Page . Such manipulation of the argument fdetails leads to sql injection. This vulnerability is uniquely identified as CVE-2026-14764...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376353>

04. CVE-2026-14763 | code-projects Hotel and Tourism Reservation 1.0 Tour Reservations Page /admin/tour_reserves.php tour sql injection

A vulnerability has been found in code-projects Hotel and Tourism Reservation 1.0 and classified as critical . This affects an unknown function of the file /admin/tour_reserves.php of the component Tour Reservations Page . This manipulation of the argument tour causes sql injection. This vulnerability is handled as CVE-2026-14763...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376352>

05. CVE-2026-14762 | code-projects Hotel and Tourism Reservation 1.0 Room Management Page /admin/rooms.php delete sql injection

A vulnerability, which was classified as critical , was found in code-projects Hotel and Tourism Reservation 1.0 . The impacted element is an unknown function of the file /admin/rooms.php of the component Room Management Page . The manipulation of the argument delete results in sql injection. This vulnerability is known as CVE-2026-14762...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376351>

06. CVE-2026-14761 | radareorg radare2 up to 6.1.6 libr/util/str.c r_str_ndup/r_str_append integer overflow (Issue 26045)

A vulnerability, which was classified as problematic , has been found in radareorg radare2 up to 6.1.6 . The affected element is the function r_str_ndup/r_str_append of the file libr/util/str.c . The manipulation leads to integer overflow. This vulnerability is traded as CVE-2026-14761...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376350>

07. CVE-2026-14760 | radareorg radare2 up to 6.1.6 regprofile libr/core/disasm.c r_core_seek_arch_bits use after free (Issue 26044)

A vulnerability classified as problematic was found in radareorg radare2 up to 6.1.6 . Impacted is the function r_core_seek_arch_bits of the file libr/core/disasm.c of the component regprofile Handler . Executing a manipulation can lead to use after free. This vulnerability appears as CVE-2026-14760...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376349>

08. CVE-2026-14759 | radareorg radare2 up to 6.1.6 RBinJava Line Number Table Parser shlr/java/class.c r_bin_java_inner_classes_attr_calc_size heap-based overflow (Issue 26043)

A vulnerability classified as problematic has been found in radareorg radare2 up to 6.1.6 . This issue affects the function r_bin_java_inner_classes_attr_calc_size of the file shlr/java/class.c of the component RBinJava Line Number Table Parser...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376348>

09. CVE-2026-14758 | radareorg radare2 up to 6.1.6 hexpairs Parser libr/core/cmd_anal.inc.c cmd_anal_opcode integer overflow (Issue 26042)

A vulnerability described as problematic has been identified in radareorg radare2 up to 6.1.6 . This vulnerability affects the function `cmd_anal_opcode` of the file `libr/core/cmd_anal.inc.c` of the component hexpairs Parser . Such manipulation leads to integer overflow. This vulnerability is documented as CVE-2026-14758...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376347>

10. CVE-2026-14757 | radareorg radare2 up to 6.1.6 libr/core/cmd_anal.inc core_anal_bytes integer overflow (Issue 26041)

A vulnerability marked as critical has been reported in radareorg radare2 up to 6.1.6 . This affects the function `core_anal_bytes` of the file `libr/core/cmd_anal.inc` . This manipulation causes integer overflow. This vulnerability is registered as CVE-2026-14757...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376346>

Data Breach & Cybercrime (10)

01. JadePuffer ransomware used AI agent to automate entire attack

Researchers identified what they believe is the first documented case of a ransomware operation, JadePuffer, conducted entirely by a large language model (LLM) agent. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/jadepuffer-ransomware-used-ai-agent-to-automate-entire-attack/>

02. U.S. Government Entity Paid Kairos \$1 Million in Data-Theft Extortion Case

A U.S. government entity paid about \$1 million to keep stolen files from being leaked, according to a new case study by Rakesh Krishnan for Ransom-ISAC, built on a leaked negotiation chat and the blockchain trail the payment left. The odd part: the group that took the money calls itself Kairos, but it may not be a ransomware gang at all. Krishnan found no s...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://thehackernews.com/2026/07/us-government-entity-paid-kairos-group.html>

03. [+24h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 27

FBI apprehends IRGC-linked cybercriminal, Russian hackers steal Signal backup keys, and unknown hackers breach the DHS information network.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-27-7/>

04. [+24h Old] Qilin Dominates Ransomware Market Amid Growing Cybercrime Consolidation

The ransomware landscape is reconsolidating around major players, with Qilin emerging as the leading RaaS operation, researchers say

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/qilin-dominates-ransomware-market/>

05. [+24h Old] Cyber readiness for SMBs: Getting the basics right

AI is changing cybercrime, but SMB cyber readiness still largely depends on closing the familiar gaps

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.welivesecurity.com/en/business-security/cyber-readiness-smbs-getting-basics-right/>

06. [+24h Old] Warning Over “Industrialized” Cyber-Attacks After Ransomware Gang Partners With TeamPCP

Researchers warn that collaboration could lead to “unprecedented” ransomware attacks, as FBI also issues warning

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/industrialized-cyberattacks/>

07. [+24h Old] Medtronic Data Breach Impacts 3.8 Million People

In April, ShinyHunters accessed the company's corporate IT systems and stole patients' personal and medical information. The post Medtronic Data Breach Impacts 3.8 Million People appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/medtronic-data-breach-impacts-3-8-million-people/>

08. [+48h Old] Aussies Face Reduced Cybercrime Risk, as Pressure Shifts to SMBs

Improved institutional safeguards and stricter regulations have pushed the burdens of protection and risk reduction on to Australian businesses.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cybersecurity-analytics/aussies-face-reduced-cybercrime-risk-pressure-shifts-smb>s

09. [+48h Old] DHS investigating breach of intelligence sharing platform

Hackers reportedly gained access to HSIN servers in late May and early June, potentially exposing sensitive but unclassified information.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/dhs-investigating-breach-of-intelligence-sharing-platform>

10. [+48h Old] 1st 'agentic ransomware' JADEPUFFER invades database at machine speed

The LLM fixed a failed login attempt within 31 seconds, demonstrating real-time adaptability.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/news/1st-agentic-ransomware-jadepuffer-invades-database-at-machine-speed>